

개 선

제 목 ERP 정보시스템 사용자 계정 및 권한 관리 미흡

관 계 부 서 ☆☆☆☆☆처

내 용

공사 정보시스템(ERP)의 사용자 권한은 업무상 필요 범위에 따라 주어져야 하며, 그 주어지는 권한이 부족하거나 지나침이 없도록 설정되어야 한다. 또한 보직변경(퇴직/이동) 등으로 인한 변경사항 발생 시 각 ERP 모듈담당자(이하 ‘모듈담당자’라 함)는 「정보시스템(ERP) 운영지침」¹⁾에 따라 사용자 계정에 대한 변경작업을 수행하여야 하며, 부서장 승인을 득한 후 Basis 모듈담당자(이하 ‘전산담당자’라 함)에게 요청하여야 한다.

관련하여 감사기간 중 ERP 정보시스템의 사용자 계정 및 권한 관리에 대하여 점검한 결과, 아래와 같은 문제점이 발견되었다.

개인정보 조회권한 과다 부여

개인정보 조회권한이 부여된 계정을 세부적으로 확인한 결과 ◇◇팀 조직관리

1) 「정보시스템(ERP) 운영지침」 주요 내용

5. ERP 시스템 계정관리

가. 사용자 계정(User ID)의 등록 및 변경 절차

- ① 모듈별로 등록된 사용자계정에 대한 변경을 요하는 작업(신규등록, 삭제, 변경 등)이 필요 시 Basis 모듈담당자는 인사발령 문서에 의해 시스템변경신청서를 작성하여 관리부서장의 승인을 득한 후 시스템에 반영한다
- ② 모듈담당자는 신청된 내용에 대해 관련된 사용자계정 및 기 부여된 역할에 대해 검토한 후 사용자계정을 관리하는 Basis에 게 반영을 요청한다
- ③ 보직변경(퇴직/이동) 등에 따른 변경사항 발생 시 모듈담당자는 현업부서의 신청과 별개로 기 등록된 사용자계정에 대한 변경작업을 부서장의 승인을 득한 후 Basis 담당자에게 반영 요청하여야 한다

담당자에게 계좌번호 조회권한, ◆◆◆◆팀 담당자에게 자격증 조회권한 등을 각각 부여하였다.

◇◇팀 조직관리 담당자는 임직원의 직무분석을 통한 공사 조직을 적정하게 운영하는 업무를 수행하고 있으므로, 임직원의 계좌번호는 업무와 관련성이 현저히 떨어지며, ◆◆◆◆팀 건강관리실 담당자는 직원의 건강관리 및 건강검진 업무를 수행하고 있으므로 자격증 조회권한은 역시 불필요한 것으로 판단된다.

임직원에게 개인정보 조회권한 기회가 증가하면 이에 비례하여 열람 정보에 대한 유출 가능성도 커지므로 담당자별 적정한 업무수행을 보장함과 동시에 임직원 개인정보 보호 또한 병행될 수 있도록 하여야 한다.

사용자 계정별 권한관리 재검토 필요

공사는 ERP시스템 운영 관련 감사일 현재 224개 사용자 계정을 운영하고 있으며, 482개 권한을 업무에 따른 사용자 계정에 각각 부여하고 있다. 사용자 계정별 권한 부여 시 부서(또는 팀) 수행업무 등을 고려하여 사용권한이 부여되어야 한다.

그러나 이번 감사에서 계정별 권한 부여 적절성 여부를 조사한 결과, 일부 계정은 다음과 같이 수행업무와 밀접하게 연관되지 않은 권한도 포함된 사례가 있었으며, 발견된 사례는 다음과 같다.

조직 수행업무 등을 고려할 경우 권한에 대한 재검토가 필요한 사례

구분	사 례	비고
1	■베트남사무소 유관부서가 아닌 부서에 현지 생산물 조회 조회권한 부여	29건
2	■카작/우즈벡/가스전 유관부서가 아닌 부서에 현지 관리회계 및 예산 레포트 조회권한 부여	109건
3	■비축본부 이외에 비축유 재고, 비축유관리 등 조회권한 부여	96건

현재 부서의 업무영역과 직접관련성이 떨어지는 계정도 일부 권한이 부여된 이유는 ERP 도입 시 해당조회 권한을 전사적으로 일괄 부여한 후 별도의 회수 조치 없이 현재까지 이어진 데 그 원인이 있다.

수행업무와 직접 관련되지 않더라도 공사업무 진행현황을 공사 임직원이 공유함으로써 부서 등 조직 간 업무정보 단절에 따른 폐해를 방지하는 순기능이 있으나, 다른 한편으로는 해당사업의 중요 경영정보에 대한 노출빈도를 높임으로써 중요 경영정보가 외부로 유출될 가능성을 높이는 위험도 발생할 수 있을 것이다.

따라서 관련부서와 협의를 통하여 권한부여의 타당성에 대한 종합적인 검토를 통하여 사용자 계정별로 적절한 범위 내에서 ERP 시스템 권한이 부여되도록 조정이 필요하다.

사용자 계정변경 승인 미실시

현재 보직변경 등으로 정보시스템(ERP)에 대한 사용자 계정변경이 필요할 경

우 시스템 관리자는 실무자간 협의를 통하여 사용자 계정을 변경하고 있으며, 관리부서장의 승인을 득하는 절차는 별도로 운영하지 않고 있다.

공사 「정보시스템(ERP) 운영지침」 ‘5. ERP 시스템 계정관리’에 따르면 사용자계정에 대한 변경을 요하는 작업이 필요 시 관리부서장의 승인을 득한 후 시스템에 반영하도록 되어 있다.

따라서 현재 운영되고 있는 정보시스템(ERP) 계정변경 방식은 규정을 위반한 것으로서 임의적인 정보시스템 권한부여 및 삭제로 운영될 우려가 있어 정보유출 사고의 원인이 될 수 있으므로 계정변경 절차 운영 방식에 대한 개선이 필요하다.

조치할 사항

☆☆☆☆☆처장은 현업부서의 의견 등을 고려하여 개인정보 조취권한과 계정별 권한을 재검토하여 ERP 정보시스템 사용자 계정 및 권한이 업무범위에 맞도록 관리하시고, 향후 인사이동 등에 따른 사용자계정 변경 시 반드시 운영지침에 규정된 승인절차를 준수하시기 바랍니다. (개선)